Informe de Pentesting

Marzo, 2026

Realizado por:
Anied Arpisa Vásquez

1. Control de versiones:

Version	Fecha	Responsable	Comentarios
V.1	08/03/2026	Anied Arpisa Vásquez	Sin novedad

Tabla de contenido

1. Control de versiones: 2
2. Introducción: 4
3. Objetivo 5
4. Alcance 5
5. Metodología: 5
6. Fases del Pentesting: 6
   a) Fase de Reconocimiento: 6
   b) Fase de Exploración: 6
   c) Fase de Análisis de Vulnerabilidades: 6
7. Vulnerabilidades Detectadas: 7
8. Análisis de Impacto y Explotabilidad 12
9. Propuesta de Prevención 15
10. Propuesta de Mitigación 15
11. Conclusión 16

2. Introducción:

En un ecosistema tecnológico caracterizado por la evolución constante de las amenazas, la gestión de la ciberseguridad requiere un enfoque de auditoría permanente. El presente informe de Pentesting tiene como objetivo auditar y documentar la postura de seguridad de un servidor crítico perteneciente a 4Geeks Academy.

Para garantizar la tríada de la seguridad: **Confidencialidad, Integridad y Disponibilidad**, se llevó a cabo un conjunto de pruebas técnicas empleando el motor de scripts de Nmap (NSE) para el escaneo exhaustivo de vulnerabilidades.

La finalidad es mitigar riesgos de seguridad de manera preventiva, antes de que estas brechas puedan ser explotadas por actores externos.

3. Objetivo

El objetivo de este escaneo es revisar a fondo todos los posibles puntos de entrada del servidor clave de la empresa 4Geeks Academy para encontrar fallos de seguridad graves y así evitar que algún usuario externo y sin permisos comprometa la seguridad y los datos del sistema.

4. Alcance

El alcance de esta auditoría se centra en un servidor web clave de la empresa identificado con la dirección **IP 192.168.0.137.**

El análisis técnico comprende una inspección de todos los puertos TCP mediante el parámetro -p-, la identificación de versiones de servicios con -sV y el despliegue de scripts de la categoría vuln.

5. Metodología:

La ejecución de este análisis se realizó bajo un modelo de Grey Box. Esta metodología se sitúa en un punto intermedio, ya que, se conoce la siguiente información:

- Dirección IP: 192.168.0.137
- Servidor web de la empresa.

6. Fases del Pentesting:

a) Fase de Reconocimiento:

Etapa inicial en la que el objetivo fue confirmar la disponibilidad del servidor web identificado en la red con la dirección IP **192.168.0.137**. Se verificó la conectividad mediante el protocolo ICMP para asegurar que el servidor estaba operativo antes de proceder con las pruebas.

b) Fase de Exploración:

Se realizó la identificación total del servidor. A diferencia de un escaneo rápido, se optó por una inspección de rango completo, es decir, los 65,535 puertos.

Se usó la técnica de Escaneo de tipo **SYN Stealth** para identificar puertos abiertos. Adicionalmente, se realizó un análisis de banners para extraer versiones específicas del software en ejecución.

El escaneo se limitó a la capa de transporte (TCP). No se incluyeron pruebas de denegación de servicio (DoS) ni ataques de fuerza bruta para garantizar la estabilidad y disponibilidad del servidor web durante la prueba.

c) Fase de Análisis de Vulnerabilidades:

Una vez mapeados los servicios, se ejecutó una fase de contraste automatizado. Se utilizaron scripts avanzados para buscar fallos conocidos (CVEs), configuraciones de seguridad por defecto y debilidades en los protocolos de comunicación.

7. Vulnerabilidades Detectadas:

Se realizó un análisis completo al servidor web, abarcando todas las áreas críticas para analizar posibles brechas de seguridad en los servicios, y así, aplicar configuraciones defensivas que protejan tanto la estabilidad del servidor como la información que este gestiona.

Se llevaron a cabo las siguientes acciones:

a) Un scan básico para identificar los puertos abiertos, los servicios y las versiones de cada uno.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.0.137
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 21:29 -0500
Nmap scan report for 192.168.0.137
Host is up (0.00074s latency).
Not shown: 65532 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.62 ((Debian))
MAC Address: 08:00:27:D4:3A:A5 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.46 seconds

┌──(kali㉿kali)-[~]
└─$
```

Imagen 1

Como resultado se observa lo siguiente:

Puerto	Servicio	Versión	Observación	Nivel de Criticidad	Riesgos asociados
21	FTP	Vsftpd 3.0.3	Puerto usado para la transferencia de archivos.	**Alta**	Falta de cifrado Ataques de Sniffing Vulnerabilidades de Software
22	SSH	OpenSSH 9.2	Puerto usado para permitir el acceso remoto seguro a la terminal del servidor.	**Alta**	Ataques de Fuerza Bruta Acceso Total Riesgo de Configuración

Puerto	Servicio	Versión	Observación	Nivel de Criticidad	Riesgos asociados
80	HTTP	Apache Httpd 2.4.62	El puerto 80 es el estándar para el tráfico HTTP (páginas web sin cifrar).	**Media/Alta**	Tráfico no cifrado Exploits de Aplicación Denegación de Servicio

Posteriormente, se realizó un scan exhaustivo para identificar las vulnerabilidades críticas existentes en los servicios activos.

```
# Nmap 7.98 scan initiated Sun Mar  8 20:15:26 2026 as: /usr/lib/nmap/nmap --privileged -sV -p- --script=vuln -oN /home/kali/Desktop/vulnerabilidades.txt 192.168.0.137
Nmap scan report for 192.168.0.137
Host is up (0.00031s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE    SERVICE  VERSION
21/tcp   open     ftp      vsftpd 3.0.3
| vulners:
|   vsftpd 3.0.3:
|       CVE-2021-30047  7.5 https://vulners.com/cve/CVE-2021-30047
|_      CVE-2021-3618   7.4 https://vulners.com/cve/CVE-2021-3618
22/tcp   open     ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| vulners:
|   cpe:/a:openbsd:openssh:9.2p1:
|       PACKETSTORM:179290  10.0    https://vulners.com/packetstorm/PACKETSTORM:179290  *EXPLOIT*
|       1EEC8894-D2F7-547C-827C-915BE866875C    10.0    https://vulners.com/githubexploit/1EEC8894-D2F7-547C-827C-915BE866875C  *EXPLOIT*
|       PACKETSTORM:173661  9.8 https://vulners.com/packetstorm/PACKETSTORM:173661  *EXPLOIT*
|       F0979183-AE88-53B4-86CF-3AF0523F3807    9.8 https://vulners.com/githubexploit/F0979183-AE88-53B4-86CF-3AF0523F3807  *EXPLOIT*
|       CVE-2023-38408  9.8 https://vulners.com/cve/CVE-2023-38408
|       CVE-2023-28531  9.8 https://vulners.com/cve/CVE-2023-28531
```

Imagen 2

```
80/tcp   open     http     Apache httpd 2.4.62 ((Debian))
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=192.168.0.137
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://192.168.0.137:80/manual
|     Form id: wp-block-search__input-2
|     Form action: http://localhost/
|
|     Path: http://192.168.0.137:80/apache2;repeatmerged=0
|     Form id: wp-block-search__input-2
|_    Form action: http://localhost/
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-server-header: Apache/2.4.62 (Debian)
| vulners:
|   cpe:/a:apache:http_server:2.4.62:
|       PACKETSTORM:213257  9.1 https://vulners.com/packetstorm/PACKETSTORM:213257  *EXPLOIT*
|       CVE-2025-23048  9.1 https://vulners.com/cve/CVE-2025-23048
|       CNVD-2025-16610 9.1 https://vulners.com/cnvd/CNVD-2025-16610
```

Imagen 3

b) Se verificó el estado de las conexiones de red activas en el sistema. Los resultados detallan una lista de puertos abiertos y servicios que están actualmente en espera de tráfico entrante.

```
debian@debian:/$ ss -tunap
Netid   State    Recv-Q   Send-Q              Local Address:Port        Peer Address:Port   Process
udp     UNCONN   0        0                        0.0.0.0:5353             0.0.0.0:*
udp     UNCONN   0        0                        0.0.0.0:52982            0.0.0.0:*
udp     ESTAB    0        0            192.168.0.137%enp0s3:68           192.168.0.1:67
udp     UNCONN   0        0                           [::]:60619               [::]:*
udp     UNCONN   0        0                           [::]:5353                [::]:*
tcp     LISTEN   0        128                     127.0.0.1:631             0.0.0.0:*
tcp     LISTEN   0        128                       0.0.0.0:22              0.0.0.0:*
tcp     LISTEN   0        80                      127.0.0.1:3306            0.0.0.0:*
tcp     LISTEN   0        128                         [::1]:631               [::]:*
tcp     LISTEN   0        511                            *:80                    *:*
tcp     LISTEN   0        128                         [::]:22                 [::]:*
tcp     LISTEN   0        32                             *:21                    *:*
```

Imagen 4

- Se observa el servicio SSH asociado al puerto 22 en estado *listen* para permitir el acceso remoto a la terminal del servidor desde cualquier red.
- En el puerto 80, el servidor web Apache está configurado para aceptar conexiones en todas las tarjetas de red disponibles del equipo.
- En el puerto 21, el servidor de transferencia de archivos (FTP) está configurado para aceptar conexiones en todas las interfaces de red del sistema

c) Se verifican los usuarios de la base de datos del servidor web y se obtiene lo siguiente:

```
MariaDB [(none)]> SELECT user, host, password FROM mysql.user;
+---------------+-----------+-------------------------------------------+
| User          | Host      | Password                                  |
+---------------+-----------+-------------------------------------------+
| mariadb.sys   | localhost |                                           |
| root          | localhost | *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 |
| mysql         | localhost | invalid                                   |
| wordpressuser | localhost | *6BB4837EB74329105EE4568DDA7DC67ED2CA2AD9 |
| user          | localhost | *2470C0C06DEE42FD1618BB99005ADCA2EC9D1E19 |
+---------------+-----------+-------------------------------------------+
5 rows in set (0.001 sec)
```

Imagen 5

Se identificaron vulnerabilidades críticas de credenciales.

- Reutilización de claves por parte de los usuarios *root* y *wordpressuser*.

- Hashes con prefijo de asterisco y longitud de 40 caracteres hexadecimales, lo que confirma el algoritmo de cifrado MySQL SHA1, el cual es un cifrado débil ante ataques de fuerza bruta modernos.
- Uso de contraseñas predecibles o débiles.

d) Se realiza un escaneo del servidor con la herramienta *Rootkit Hunter* para detectar rootkits o malware, en donde se evidenciaron 3 alertas de *warning:*

- Warning en /usr/bin/lwp-request:

```
/usr/bin/lwp-request                                        [ Warning ]
```

Tras una inspección manual con el comando file, se confirmó que se trata del script de Perl legítimo del sistema. Se determina que es un falso positivo, aunque se mantiene bajo vigilancia por ser una herramienta que permite conexiones salientes.

```
debian@debian:/$ file /usr/bin/lwp-request
/usr/bin/lwp-request: Perl script text executable
debian@debian:/$
```

- Segmentos de memoria compartida sospechosos:

```
Checking for suspicious (large) shared memory segments   [ Warning ]
```

Al verificar con el comando ipcs -m, se observó que los segmentos pertenecen a servicios legítimos.

```
debian@debian:/$ ipcs -m

------ Shared Memory Segments --------
key        shmid      owner      perms      bytes      nattch     status
0x00000000 98306      debian     600        524288     2          dest
0x00000000 8          debian     600        524288     2          dest
0x00000000 13         debian     600        4194304    2          dest
0x00000000 16         debian     600        524288     2          dest
0x00000000 19         debian     600        524288     2          dest
0x00000000 22         debian     600        524288     2          dest
0x00000000 25         debian     600        524288     2          dest
0x00000000 28         debian     600        524288     2          dest
0x00000000 34         debian     600        524288     2          dest
0x00000000 36         debian     600        33554432   2          dest
0x00000000 39         debian     600        4194304    2          dest
0x00000000 32813      debian     600        33554432   2          dest
```

- Acceso root por SSH está permitido:

```
Checking if SSH root access is allowed                    [ Warning ]
```

Esto representa una vulnerabilidad crítica de configuración

```
debian@debian:/$ grep "PermitRootLogin" /etc/ssh/sshd_config
PermitRootLogin yes
# the setting of "PermitRootLogin prohibit-password".
debian@debian:/$
debian@debian:/$
```

e) Se verificó el firewall de IPTABLES y no se evidencian reglas para filtrar, bloquear o redirigir el tráfico no deseado.

```
debian@debian:~$ sudo iptables -L
sudo: iptables: command not found
debian@debian:~$
```

f) Se verifican las tareas programadas CRONTAB para asegurar que no existan acciones maliciosas que se ejecuten automáticamente tras un reinicio del sistema o en intervalos específicos.

```
debian@debian:~$ crontab -l
no crontab for debian
debian@debian:~$ sudo crontab -l
no crontab for root
```

g) Se verifican los permisos de los archivos claves de mi servidor web

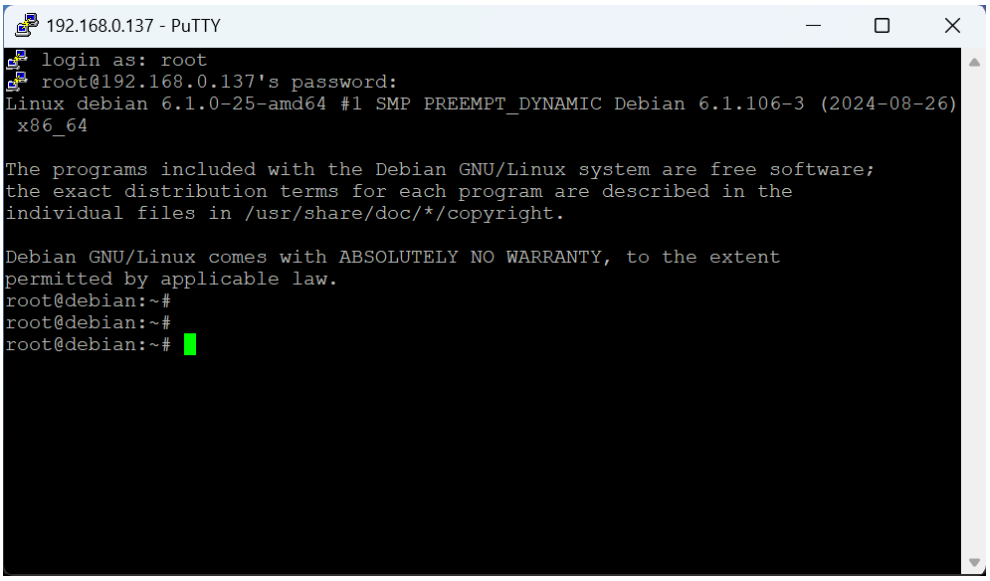
```
debian@debian:~$ sudo ls -l /var/www/html/
total 252
-rwxrwxrwx  1 www-data www-data 10701 Sep 30  2024 index.html
-rwxrwxrwx  1 www-data www-data   405 Feb  6  2020 index.php
-rwxrwxrwx  1 www-data www-data 19903 Feb 23 21:20 license.txt
-rwxrwxrwx  1 www-data www-data  7425 Mar 10 23:25 readme.html
-rwxrwxrwx  1 www-data www-data  7349 Feb 23 21:20 wp-activate.php
drwxrwxrwx  9 www-data www-data  4096 Sep 10  2024 wp-admin
-rwxrwxrwx  1 www-data www-data   351 Feb  6  2020 wp-blog-header.php
-rwxrwxrwx  1 www-data www-data  2323 Jun 14  2023 wp-comments-post.php
-rwxrwxrwx  1 www-data www-data  3017 Sep 30  2024 wp-config.php
-rwxrwxrwx  1 www-data www-data  3339 Feb 23 21:20 wp-config-sample.php
drwxrwxrwx  6 www-data www-data  4096 Mar 10 23:25 wp-content
-rwxrwxrwx  1 www-data www-data  5617 Feb 23 21:20 wp-cron.php
drwxrwxrwx 31 www-data www-data 16384 Feb 23 21:20 wp-includes
-rwxrwxrwx  1 www-data www-data  2493 Feb 23 21:20 wp-links-opml.php
-rwxrwxrwx  1 www-data www-data  3937 Mar 11  2024 wp-load.php
-rwxrwxrwx  1 www-data www-data 51437 Feb 23 21:20 wp-login.php
-rwxrwxrwx  1 www-data www-data  8727 Feb 23 21:20 wp-mail.php
-rwxrwxrwx  1 www-data www-data 31055 Feb 23 21:20 wp-settings.php
-rwxrwxrwx  1 www-data www-data 34516 Feb 23 21:20 wp-signup.php
-rwxrwxrwx  1 www-data www-data  5214 Feb 23 21:20 wp-trackback.php
-rwxrwxrwx  1 www-data www-data  3205 Feb 23 21:20 xmlrpc.php
debian@debian:~$
```

8. Análisis de Impacto y Explotabilidad

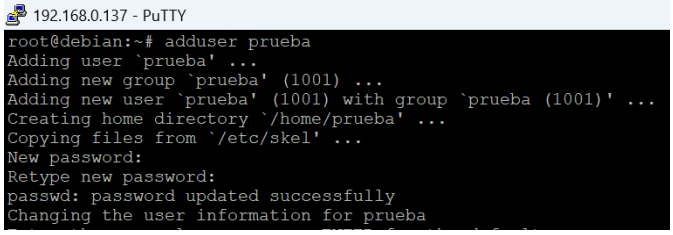
Con los resultados obtenidos de las pruebas realizadas, se evidencia un nivel muy bajo de la seguridad del servidor en cuestión.

a) El primer resultado permite conocer aquellos puertos que son visibles desde el exterior, los servicios asociados y las versiones de cada uno. Conocer la información de los servicios y versiones es el primer paso para todo atacante.

b) En los resultados mostrados previamente se observó que el puerto 22 está abierto y que el acceso root por SSH está activado. Con esta información solo basta con un ataque de fuerza bruta para la conexión al servidor



Una vez ingresamos al servidor web con el usuario root, tenemos el control total para obtener información confidencial, navegar entre los directorios. De esta forma se confirma la grave falla de seguridad.



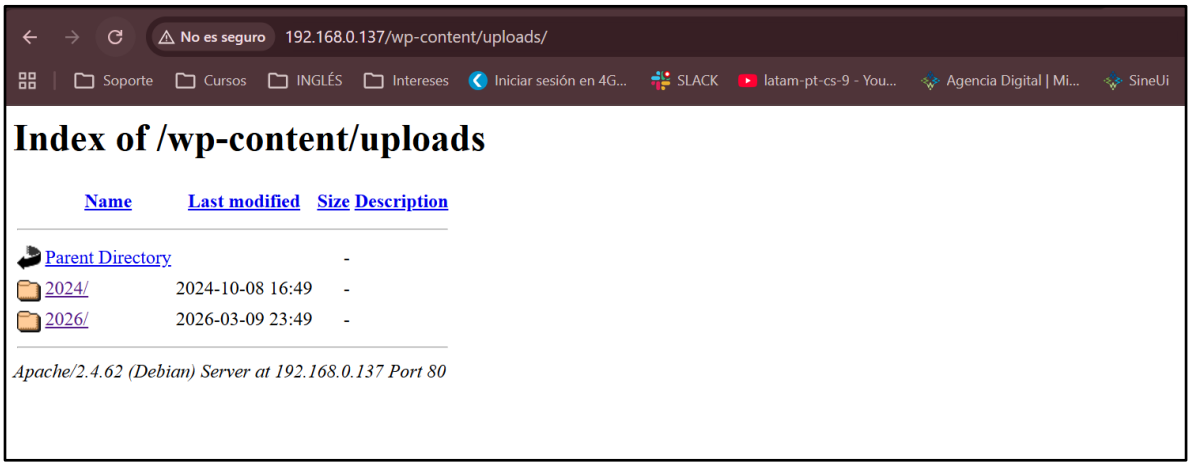
```
root@debian:~# ls -la
total 44
drwx------  6 root root 4096 Oct  8  2024 .
drwxr-xr-x 19 root root 4096 Sep 30  2024 ..
-rw-------  1 root root  127 Jul 31  2024 .bash_history
-rw-r--r--  1 root root  571 Apr 10  2021 .bashrc
drwx------  2 root root 4096 Jul 31  2024 .cache
drwx------  3 root root 4096 Jul 31  2024 .config
-rw-------  1 root root   20 Oct  8  2024 .lesshst
drwxr-xr-x  3 root root 4096 Jul 31  2024 .local
-rw-------  1 root root  609 Sep 30  2024 .mysql_history
-rw-r--r--  1 root root  161 Jul  9  2019 .profile
drwx------  2 root root 4096 Jul 31  2024 .ssh
root@debian:~#
root@debian:~# cd ../
root@debian:/# ls
bin   etc         initrd.img.old  lost+found  opt   run   sys  var
boot  home        lib             media       proc  sbin  tmp  vmlinuz
dev   initrd.img  lib64           mnt         root  srv   usr  vmlinuz.old
root@debian:/# cd home/
root@debian:/home# ls -la
total 16
drwxr-xr-x  4 root   root   4096 Mar 10 00:01 .
drwxr-xr-x 19 root   root   4096 Sep 30  2024 ..
drwx------ 14 debian debian 4096 Mar  9 23:47 debian
drwx------  2 prueba prueba 4096 Mar 10 00:01 prueba
root@debian:/home#
```

c) El puerto 80 abierto es el inicio para escanear el sitio web wordpress. Para esta tarea usaremos el comando wpscan.

```
kali@kali: ~
Session  Actions  Edit  View  Help

        WordPress Security Scanner by the WPScan Team
                         Version 3.8.28
      Sponsored by Automattic - https://automattic.com/
      @_WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.0.137/ [192.168.0.137]
[+] Started: Tue Mar 10 00:29:24 2026

Interesting Finding(s):

[+] Headers
 | Interesting Entry: Server: Apache/2.4.62 (Debian)
 | Found By: Headers (Passive Detection)
 | Confidence: 100%

[+] robots.txt found: http://192.168.0.137/robots.txt
 | Interesting Entries:
 |  - /wp-admin/
 |  - /wp-admin/admin-ajax.php
 | Found By: Robots Txt (Aggressive Detection)
 | Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.0.137/xmlrpc.php
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
 | References:
 |  - http://codex.wordpress.org/XML-RPC_Pingback_API
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
 |  - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
 |  - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.0.137/readme.html
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%

[+] Upload directory has listing enabled: http://192.168.0.137/wp-content/uploads/
 | Found By: Direct Access (Aggressive Detection)
 | Confidence: 100%
```

En los resultados se listan varios hallazgos, sin embargo, para efectos de este análisis nos enfocaremos en:

[+] Upload directory has listing enabled: http://192.168.0.137/wp-content/uploads/
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

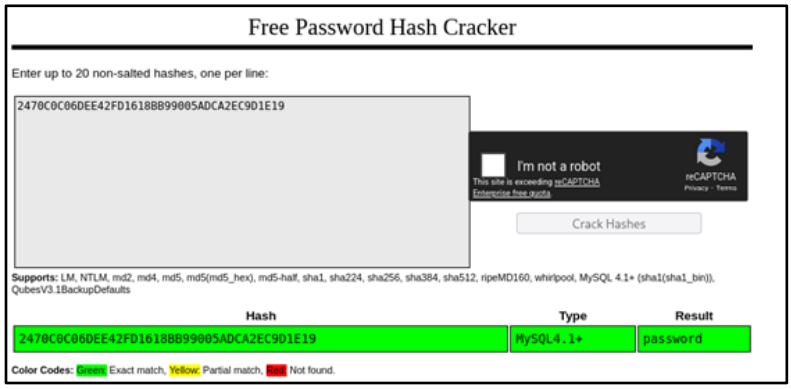


Esta vulnerabilidad es crítica porque al acceder directamente a esa URL en un navegador, el servidor no muestra una página en blanco o un error, sino que muestra una lista de todos los archivos y carpetas, y permite descargar todo el contenido multimedia y documentos de la web sin restricción.

d) Con el cifrado débil de los hashes de las contraseñas de los usuarios de las bases de dato, es muy fácil descubrir las contraseñas de los usuarios.

HASH 1:

HASH 2:



9. Propuesta de Prevención

El objetivo de estas medidas es establecer barreras proactivas que eviten la aparición de nuevas vulnerabilidades y dificulten el reconocimiento por parte de atacantes:

- **Implementación de Políticas de Contraseñas Robustas:** Establecer una política que exija contraseñas complejas, evitando la reutilización de claves entre usuarios críticos como root y wordpressuser
- **Gestión de Actualizaciones y Parches:** Establecer un calendario de mantenimiento para asegurar que el servidor Apache, OpenSSH y vsftpd se mantengan en sus versiones más recientes y seguras.
- **Cifrado por Defecto:** Migrar todos los servicios de transmisión de datos a versiones cifradas (HTTP a HTTPS y de FTP a SFTP o FTPS).
- **Configuración de Firewall:** Implementar reglas estrictas en IPTABLES, permitiendo únicamente el tráfico necesario desde IPs autorizadas.
- **Hardening de SSH:** Configurar el servicio para prohibir el acceso directo al usuario root.
- **Implementación de un IDS:** Instalar herramientas de IDS para monitorear cambios en los permisos de los archivos y generar alertas automáticas si algo vuelve a cambiar a 777.

10. Propuesta de Mitigación

Estas acciones están diseñadas para corregir de forma inmediata las brechas de seguridad críticas expuestas durante el pentesting:

- **Corrección de SSH:** Modificar el archivo de configuración de SSH para desactivar el acceso root (PermitRootLogin no) y así eliminar la posibilidad de comprometer el sistema mediante fuerza bruta directa a dicha cuenta.
- **Aseguramiento de WordPress:** Desactivar de inmediato el listado de directorios (Directory Listing) en la ruta /wp-content/uploads/ mediante la configuración de Apache, evitando la descarga no autorizada de documentos.
- **Actualización de Seguridad en Base de Datos:** Cambiar las contraseñas de los usuarios de la base de datos y migrar los hashes de MySQL SHA1 a algoritmos de cifrado más fuertes y modernos para resistir ataques de fuerza bruta.
- **Cierre de Puertos:** Evaluar la necesidad de los puertos abiertos que no están siendo utilizados.

- **Monitoreo de Integridad:** Mantener bajo vigilancia aquellas herramientas que pueden ser utilizadas para conexiones salientes no deseadas.
- **Reestructuración de permisos**: El objetivo es revocar los privilegios de escritura y ejecución global (777) que permiten a cualquier usuario del sistema modificar el código fuente.

11. Conclusión

El análisis técnico revela que el servidor web de 4Geeks Academy presenta un nivel de seguridad muy bajo, con fallos que comprometen directamente la tríada de la seguridad: confidencialidad, integridad y disponibilidad.

La combinación de puertos críticos abiertos (21, 22, 80), configuraciones de software por defecto y la falta de reglas de filtrado en el firewall permite que un atacante externo pueda obtener control total del servidor.

Adicionalmente, es alarmante la exposición de archivos en WordPress y el uso de cifrado débil en las credenciales de la base de datos, lo que facilita la exfiltración de información sensible.